

LEARNING RESOURCE GUIDE

ISC2 CCSP: Certified Cloud Security Professional (Aug 2026) | Professional Participant Workbook

Patch Management and High Availability of Clustered Hosts

1. Learning Objectives

By the end of this lecture, you will be able to:

- Describe the full patch management lifecycle from vulnerability identification through verified deployment.
- Explain CVSS scoring and the Known Exploited Vulnerabilities catalogue as prioritisation inputs.
- Distinguish between traditional OS patching and immutable infrastructure patching patterns.
- Explain how VMware DRS and HA enable rolling patch deployment with no workload downtime.
- Articulate why clustering and high availability do not replace backup, and what each layer protects.

2. Introduction

A global logistics company maintained a mature change management process. Every patch was tested in a staging environment, approved through a change advisory board, and applied during a scheduled maintenance window. The process was sound. The problem was the window: maintenance was scheduled monthly. When a critical vulnerability in a widely used network file-sharing protocol was published alongside an available patch, the organisation's next scheduled window was 27 days away. The decision was made to wait. Twelve days later, attackers exploiting that exact vulnerability had encrypted production systems across three data centers and a cloud environment. The patch had been available. The patch had been approved. The process was simply too slow.

Patch management occupies a unique position in cloud security operations: it is one of the most operationally mature disciplines in IT, with decades of tooling and process documentation behind it, yet it remains one of the most consistently exploited failure points in breach investigations. The gap between vulnerability disclosure, patch availability, and patch deployment is where attackers operate. This lecture covers both the process discipline required to close that gap and the high availability architecture that allows patching to happen without disrupting the services the business depends on.

For the CCSP exam, patch management appears within Domain 5 and connects to vulnerability management, change control, and availability. The exam frequently presents scenarios where candidates must distinguish between planned availability controls — such as rolling maintenance windows through a cluster — and unplanned failure response mechanisms such as HA restart.

3. Core Concepts Explained

3.1 The Patch Management Lifecycle

Patch management is a structured lifecycle, not a single activity. The lifecycle begins with identification: vulnerability intelligence feeds — the National Vulnerability Database maintained by NIST, vendor security advisories, and guidance from organisations like CISA and CIS — publish information about newly discovered vulnerabilities and available remediation. An effective patch management programme requires a reliable mechanism for ingesting this intelligence and matching it against a current software inventory. Without accurate inventory, patches cannot be targeted to the systems that need them.

Identification is followed by prioritisation. Not every vulnerability demands the same response urgency. The Common Vulnerability Scoring System (CVSS), which rates vulnerabilities from 0 to 10 based on factors including exploitability, privileges required, whether user interaction is needed, and potential impact on confidentiality, integrity, and availability, provides a structured prioritisation input. Critical and high CVSS scores generally demand rapid remediation measured in days. Medium and low scores follow standard monthly or quarterly cycles.

The most important single prioritisation signal is active exploitation. CISA maintains a Known Exploited Vulnerabilities (KEV) catalogue listing vulnerabilities actively exploited in the wild. A medium-rated vulnerability appearing in the KEV catalogue demands faster remediation than a critical-rated theoretical flaw requiring unusual local conditions to exploit. WannaCry, which exploited CVE-2017-0144, demonstrated this principle at scale: the vulnerability rated critical, a patch existed, and yet the speed and scale of exploitation caught organisations whose patching cycles had not treated the disclosure with corresponding urgency.

3.2 Testing Before Deployment

A patch that resolves a vulnerability can also introduce instability or break application compatibility. Testing in a staging environment that mirrors production configuration validates both that the vulnerability is resolved and that the patch does not disrupt workload behaviour. In cloud environments, staging environments can be provisioned rapidly, tested, and decommissioned without long lead times — a structural advantage over traditional on-premises pre-production infrastructure. The staging environment must closely mirror production configuration, including OS version, installed packages, and application dependencies, or the validation is not meaningful.

3.3 Immutable Infrastructure Patching

Container and microservices deployments frequently use immutable infrastructure patterns where patching works fundamentally differently. Rather than updating a running instance, the base container image or virtual machine image is updated with the required patch and new instances are deployed from the patched image while old instances are terminated. This eliminates configuration drift — every running instance reflects the current baseline by definition — but it requires a well-managed image build pipeline, image

version tracking, and a distribution mechanism that can push new images across a large fleet quickly. Immutable infrastructure patching shifts the operational discipline from 'apply a patch to a running system' to 'rebuild and redeploy the system from a patched image.'

3.4 VMware Distributed Resource Scheduling (DRS)

DRS continuously monitors CPU and memory utilisation across all hosts in a VMware cluster. When one host is under heavy load and another has spare capacity, DRS uses live migration — vMotion — to move running virtual machines from the congested host to the less-loaded one. The migration happens while the VM is running; from the guest OS perspective there is no interruption. DRS can be configured to make migration recommendations for administrators to approve manually or to execute migrations automatically based on defined thresholds. For patch management, DRS's relevance is direct: when a host needs to be patched, placing it into maintenance mode triggers DRS to migrate all running VMs off that host using vMotion. The now-empty host is patched and rebooted without any workload being interrupted. Rolling this process through each host in sequence allows an entire cluster to be patched with no scheduled downtime for the workloads running on it.

3.5 VMware High Availability (HA)

HA addresses unplanned failure rather than planned maintenance. HA monitors the health of every host in the cluster. If a host fails unexpectedly, HA automatically restarts the virtual machines that were running on the failed host onto surviving cluster members. The restart introduces a brief interruption — the time required for the guest OS to boot on the new host — but it is significantly shorter than a manual recovery process and requires no administrator intervention to trigger. HA also monitors virtual machine health and can restart a VM that has stopped responding even if the underlying host remains operational.

The RTO for VMs protected by VMware HA is typically a few minutes, limited by guest OS boot time. The RPO is effectively zero for VM configuration, since shared storage remains accessible from any cluster host and no disk state is lost when a host fails. Only in-memory state at the precise moment of failure is not recoverable.

3.6 Shared Storage for Cluster High Availability

For DRS and HA to migrate or restart VMs across hosts, virtual disk files must be accessible from any host in the cluster. Traditional approaches use a storage area network (SAN) presenting shared storage volumes accessible to every cluster host. VMware's software-defined storage solution, vSAN, distributes and replicates data across local disks attached to cluster hosts. Both approaches eliminate the single point of failure that would exist if each host held exclusive local storage for its VMs. Shared storage is not optional for HA — without it, VM restart on a different host is not possible.

3.7 Clustering vs. Backup: A Critical Distinction

A cluster ensures that virtual machines can continue running when a host fails. It does not protect against data loss from deletion, corruption, ransomware encryption, or accidental

modification. If a file is deleted or corrupted, the cluster replicates that deletion or corruption across all storage copies. A storage cluster is a runtime availability mechanism; backup systems that create point-in-time copies stored independently from the primary environment are a separate and equally necessary layer. The CCSP exam regularly tests whether candidates understand this distinction.

4. Comparison: DRS vs. HA — Planned vs. Unplanned

Attribute	DRS (Distributed Resource Scheduling)	HA (High Availability)
Scenario addressed	Planned maintenance & resource balancing	Unplanned host failure
Trigger	Resource imbalance or maintenance mode	Host heartbeat loss / VM non-responsive
Migration type	Live migration (vMotion) — no downtime	Restart on surviving host — brief interruption
Workload continuity	No interruption during migration	Brief downtime for guest OS restart
Dependency	Shared storage required	Shared storage required
Use in patch management	Evacuates host before maintenance window	Not directly involved in planned patching
In-memory state preserved?	Yes — live migration preserves RAM	No — RAM state lost at point of host failure

5. Case Study: WannaCry and the Cost of a 27-Day Patch Window

Incident: In May 2017, the WannaCry ransomware worm exploited CVE-2017-0144, a vulnerability in the Windows implementation of the SMB protocol, to propagate across networks and encrypt files on infected systems. Within 24 hours it had infected more than 200,000 systems in 150 countries. Microsoft had released a patch — MS17-010 — approximately two months before WannaCry appeared. The National Health Service in the UK was among the hardest-hit organisations: thousands of appointments were cancelled, ambulances were diverted, and critical clinical systems were unavailable for days. The patch had been available. Deployment had not been prioritised with the urgency the CVSS Critical rating warranted. The incident became the defining modern example of patch management failure at scale.

WannaCry is the most cited illustration in CCSP study materials specifically because it demonstrates that patch management failure is not a technical problem — it is a process and prioritisation problem. The technical solution existed before the attack. What failed was the organisational discipline to deploy it quickly enough.

6. Analogy: Rolling Maintenance as a Ship in Dry Dock

Think of a VMware cluster as a fleet of ships maintaining a continuous cargo route. When one ship needs hull maintenance (patching), you don't halt the entire fleet and wait at port.

Instead, you shift that ship's cargo to the other vessels in the fleet (DRS live migration), take the one ship into dry dock for maintenance, and bring it back into service when done. The cargo keeps moving throughout. HA is the contingency for an emergency: if a ship sinks unexpectedly, the cargo it was carrying is loaded onto the next available vessel in the fleet as quickly as possible — there will be a brief delay while the transfer happens, but the route is not abandoned. The key distinction: dry dock is planned and seamless; emergency cargo transfer after a sinking is unplanned and involves a brief disruption.

7. Exam Focus

The CCSP exam tests patch management and HA within Domain 5. Key themes:

- CVSS scoring — understand what Critical/High/Medium/Low mean in terms of response urgency, not just numeric ranges.
- KEV catalogue — active exploitation overrides CVSS score as a prioritisation signal. A medium CVE on KEV outranks a critical CVE with no known exploitation.
- DRS vs. HA — DRS is for planned workload movement; HA is for unplanned host failure. Examiners test whether candidates can distinguish the mechanism and the trigger.
- vMotion — live migration that moves running VMs with no interruption. Prerequisite for rolling patch deployment through a cluster.
- Maintenance mode — the state that triggers DRS to evacuate a host before it is taken offline for patching.
- Shared storage requirement — both DRS and HA require shared storage accessible from all cluster hosts.
- Immutable infrastructure — patching by rebuilding and redeploying from a patched image rather than updating a running instance.
- Common distractor: 'HA protects against data loss.' It does not — it protects against prolonged service unavailability from host failure. Data protection requires backup.

8. Key Terms Glossary

CVSS: Common Vulnerability Scoring System; rates vulnerabilities 0–10 based on exploitability and impact.

KEV catalogue: CISA's Known Exploited Vulnerabilities catalogue; lists vulnerabilities actively exploited in the wild.

NVD: National Vulnerability Database; NIST-maintained repository of CVEs with CVSS scores and remediation guidance.

Patch lifecycle: The end-to-end process: identification → prioritisation → testing → deployment → verification.

vMotion: VMware live migration technology that moves a running VM between hosts with no workload interruption.

DRS: Distributed Resource Scheduling; VMware feature that balances workloads across cluster hosts and evacuates hosts entering maintenance mode.

HA (VMware): High Availability; VMware feature that restarts VMs on surviving hosts when a cluster host fails unexpectedly.

Maintenance mode: The host state that signals DRS to migrate all VMs off the host before it is taken offline.

Shared storage / vSAN: Storage accessible from all cluster hosts; prerequisite for DRS and HA to migrate or restart VMs across hosts.

Immutable infrastructure: A deployment pattern where patching works by rebuilding images and redeploying rather than updating running instances.

RTO: Recovery Time Objective; the maximum acceptable time from failure to restoration of service.

RPO: Recovery Point Objective; the maximum acceptable data loss window, measured in time.

9. Quick Revision Checklist

- ☐ I can describe all five phases of the patch management lifecycle.
- ☐ I understand CVSS score ranges and how they map to remediation urgency.
- ☐ I know what the CISA KEV catalogue is and why active exploitation overrides CVSS in prioritisation.
- ☐ I can explain how immutable infrastructure patching differs from traditional OS patching.
- ☐ I understand how DRS uses vMotion to evacuate a host before a maintenance window.
- ☐ I can explain what VMware HA does when a host fails and what the brief interruption represents.
- ☐ I know that both DRS and HA require shared storage accessible from all cluster hosts.
- ☐ I can articulate why clustering and high availability do not replace backup.
- ☐ I understand what maintenance mode is and how it triggers DRS behaviour.
- ☐ I can distinguish between the RTO and RPO implications of VMware HA.

10. Practice Questions

Scenario-Based Question 1: SCENARIO: A cloud security engineer is reviewing patch prioritisation for a set of 40 vulnerabilities identified in this month's scan. One vulnerability is rated CVSS 6.4 (Medium) and affects a widely deployed VPN gateway. A second is rated CVSS 9.1 (Critical) and requires an attacker to have local access to the system and a specific non-default configuration that does not exist in the organisation's environment. The CVSS 6.4 vulnerability appears on the current CISA Known Exploited Vulnerabilities catalogue. Which vulnerability should be patched first?

- A) The CVSS 9.1 Critical vulnerability, because it has the higher severity score and Critical-rated vulnerabilities always take precedence.
- B) The CVSS 6.4 Medium vulnerability, because it is on the CISA KEV catalogue indicating active real-world exploitation.
- C) Both should be patched simultaneously in the same maintenance window since both were identified in the same scan.
- D) The CVSS 9.1 Critical vulnerability should be deferred since the required attack conditions do not exist in the environment.

Answer: B. Correct. Active exploitation is the highest-priority signal in patch prioritisation. A medium-rated vulnerability being actively exploited in the wild against a widely deployed asset poses more immediate risk than a critical-rated vulnerability that requires conditions not present in this environment.

A: Incorrect. CVSS scores measure theoretical severity. The CVSS 9.1 vulnerability requires local access and a non-default configuration that is not present. Active exploitation in the wild — indicated by the KEV listing — is a more immediate prioritisation signal than a high theoretical score for an unexploitable flaw.

C: Incorrect. Patching simultaneously is not wrong operationally, but the question asks which should be patched first. The KEV-listed vulnerability has higher operational urgency and should be addressed before the standard maintenance cycle.

D: Incorrect. Deferring is premature — the vulnerability still needs remediation, just at lower urgency than a KEV-listed actively exploited vulnerability. Conditions can change; deferring entirely creates risk.

Scenario-Based Question 2: SCENARIO: A VMware cluster hosts 120 virtual machines across 6 ESXi hosts. The security team needs to apply a critical patch to the ESXi hypervisor software on all hosts. The patch requires a host reboot. The operations team wants to apply patches without any scheduled downtime for the workloads. Which combination of VMware capabilities enables this outcome?

- A) VMware HA and shared storage.

- B) VMware DRS with vMotion and shared storage.
- C) VMware HA and vSAN.
- D) Manual snapshot of each VM before each host enters maintenance mode.

Answer: B. Correct. Placing each host into maintenance mode triggers DRS to live-migrate all VMs off that host using vMotion to the remaining cluster members. The host is then patched and rebooted with no VM downtime. Shared storage is required so VMs are accessible from any host. Rolling this through all six hosts completes the cluster patch without workload interruption.

A: Incorrect. HA handles unplanned failures and restarts VMs after a host fails, which involves a brief service interruption. It does not provide the no-downtime live migration needed for planned maintenance patching.

C: Incorrect. HA restarts VMs after host failure with a brief interruption — this is not zero-downtime patching. vSAN provides shared storage, which is necessary but not sufficient without DRS live migration.

D: Incorrect. VM snapshots are a point-in-time copy mechanism, not a live migration technology. Taking snapshots does not move running workloads to other hosts and would not prevent downtime when the host is patched and rebooted.

Scenario-Based Question 3: SCENARIO: An organisation's cloud environment uses container workloads deployed from versioned images. The security team receives notification of a critical vulnerability in the base Linux image used by all containers. The team patches by updating the base image and redeploying containers from the new image while terminating containers running the old image. Three weeks later, a compliance audit finds that 15 percent of running containers still use the old, vulnerable image. What is the most likely root cause of this finding?

- A) VMware HA restarted containers from the old image after host failures during the deployment window.
- B) The container image build and distribution pipeline did not update all image registries used by the container orchestration platform, leaving some nodes pulling from outdated registries.
- C) The CVE was rated Critical, requiring patches to be applied within 24 hours, but the redeployment cycle took longer.
- D) Containers are inherently incompatible with immutable infrastructure patching and require in-place patching instead.

Answer: B. Correct. In immutable infrastructure environments, the image build and distribution pipeline is the patching mechanism. If registry updates are incomplete or some orchestration nodes still reference old image locations, new container instances may be deployed from the unpatched image.

A: Incorrect. HA is not involved in container orchestration image selection. Container restart policies and the container runtime determine which image is used on restart, not HA.

C: Incorrect. The time taken for redeployment is an operational concern but is not the cause of 15% of containers still running the old image after three weeks. The root cause is a pipeline coverage gap.

D: Incorrect. Containers are the most common environment for immutable infrastructure patching. In-place patching of running containers is generally not recommended; image rebuild and redeployment is the correct pattern.

Question 4: What is the primary difference between VMware DRS and VMware HA?

- A) DRS handles storage replication; HA handles compute resource balancing.
- B) DRS manages planned workload movement for resource balancing and maintenance; HA responds to unplanned host failures by restarting VMs on surviving hosts.
- C) DRS requires manual administrator action to migrate VMs; HA operates fully automatically.
- D) HA and DRS are two names for the same VMware feature.

Answer: B. Correct. This is the core distinction. DRS is proactive and planned; HA is reactive and addresses unplanned failure.

A: Incorrect. Neither DRS nor HA handles storage replication. DRS balances compute workloads across cluster hosts; HA restarts workloads after host failures.

C: Incorrect. DRS can be configured to operate automatically or in recommendation mode. HA also operates automatically. The distinction between the two is not manual vs. automatic; it is planned vs. unplanned scenarios.

D: Incorrect. DRS and HA are distinct features that address different scenarios. Both are typically enabled together in production clusters, but they serve different purposes.

Question 5: Why does the CISA KEV catalogue sometimes cause a Medium-rated CVE to be prioritised above a Critical-rated CVE?

- A) CISA recalculates CVSS scores for KEV entries, resulting in higher scores for listed vulnerabilities.
- B) A vulnerability's CVSS score reflects its theoretical severity under ideal attack conditions; active exploitation in the wild indicates real-world attacker capability that may not match theoretical conditions.

- C) Medium-rated vulnerabilities are more common and therefore more likely to affect the organisation.
- D) Critical-rated vulnerabilities are typically patched first, removing them from the catalogue and leaving only medium-rated ones.

Answer: B. Correct. CVSS is a theoretical measure. A medium-rated vulnerability being actively exploited presents a known, immediate operational risk that may exceed that of a critical-rated vulnerability requiring attack conditions not present or not yet weaponised.

A: Incorrect. CISA does not recalculate CVSS scores. KEV catalogue listing indicates active exploitation, not a higher severity score.

C: Incorrect. Frequency of occurrence is not what drives KEV prioritisation. Active exploitation by threat actors is the signal.

D: Incorrect. The CVSS score does not determine KEV listing. Vulnerabilities appear on KEV because they are being exploited, regardless of their score.

Question 6: A VMware host fails unexpectedly at 2:47 AM. Which VMware capability ensures the virtual machines that were running on it continue to be available with minimal administrator intervention?

- A) DRS automatically rebalances the remaining cluster hosts and keeps all VMs running without interruption.
- B) VMware HA detects the host heartbeat loss and restarts the affected VMs on surviving cluster hosts.
- C) vSAN automatically migrates the affected VMs to a healthy datastore on a different host.
- D) The cluster management tools queue the VMs for restart at the next scheduled maintenance window.

Answer: B. Correct. HA monitors host heartbeats. When a heartbeat is lost, HA treats the host as failed and restarts all VMs from that host on surviving cluster members. There will be a brief interruption during VM restart, but recovery is automatic.

A: Incorrect. DRS handles planned workload movement. It cannot restart VMs from a failed host because the host is offline and DRS migration requires the source host to be running.

C: Incorrect. vSAN is a storage technology that replicates data across cluster hosts. It does not directly restart VMs after a host failure; that is HA's function.

D: Incorrect. HA restarts VMs immediately upon detecting host failure, without waiting for a maintenance window.

Question 7: An organisation uses VMware HA in a five-host cluster. An attacker encrypts all files on the shared storage accessible to the cluster. After HA restarts affected VMs on surviving hosts, what is the state of the data within those VMs?

- A) The data is intact, because HA preserved a pre-encryption snapshot before restarting the VMs.
- B) The data remains encrypted because HA restarts VMs from the current shared storage state, which has already been affected by the attack.
- C) The data is recovered from the most recent HA checkpoint, which is written every 30 minutes.
- D) The data is unaffected because vSAN replication automatically maintains an unencrypted copy in a separate availability zone.

Answer: B. Correct. HA is a runtime availability mechanism. It ensures VMs restart on available hosts; it does not protect against data corruption, deletion, or encryption. The VMs restart and see the encrypted shared storage.

A: Incorrect. HA does not take snapshots before VM restarts. HA restarts VMs from the existing storage state. If the shared storage is encrypted, the restarted VMs see encrypted data.

C: Incorrect. VMware HA does not create recovery checkpoints of VM data. Checkpointing is a feature of VMware Fault Tolerance, a different and more costly mechanism, and even that protects against host failure, not storage-level ransomware.

D: Incorrect. vSAN replicates data across hosts to protect against host failure, not against ransomware. If ransomware encrypts files on the storage, vSAN replicates the encrypted state.

Question 8: During patch testing, a security engineer applies a critical OS patch to a staging VM and observes that a production application begins returning errors. What is the correct next step?

- A) Deploy the patch to production immediately, since staging behaviour may not reflect production.
- B) Investigate the application error in staging to determine whether it is a compatibility issue with the patch, then resolve the issue before production deployment.
- C) Defer the patch indefinitely since any patch that causes application errors cannot be applied.
- D) Roll back the staging environment and mark the vulnerability as accepted risk pending further vendor guidance.

Answer: B. Correct. Staging exists precisely to catch compatibility issues. The observed error must be investigated and resolved — either by configuring the application to work with the patched OS, working with the application vendor for a fix, or identifying a configuration workaround — before the patch is deployed to production.

A: Incorrect. Deploying a patch that causes application errors in staging to production without resolution is the definition of inadequate pre-production validation.

C: Incorrect. Deferral leaves the vulnerability unaddressed. The goal is to resolve the compatibility issue and deploy the patch, not to abandon it.

D: Incorrect. Rolling back staging ends the investigation without resolution. Accepted risk requires documented approval and a compensating control strategy, not simply abandoning testing.

Question 9: What is the relationship between VMware vMotion and patch management in a clustered environment?

- A) vMotion applies OS patches to running VMs without requiring the VM to be shut down.
- B) vMotion enables zero-downtime planned patching by migrating running VMs off a host before that host is taken into maintenance mode for patching.
- C) vMotion is used to transfer patch packages from a central distribution server to cluster hosts.
- D) vMotion replicates VM state to backup storage before any host maintenance window.

Answer: B. Correct. When a host enters maintenance mode, DRS uses vMotion to live-migrate all running VMs to other cluster members. This empties the host so it can be patched and rebooted without any workload downtime.

A: Incorrect. vMotion moves a running VM between hosts; it does not apply patches. OS patching is a separate process.

C: Incorrect. vMotion migrates running VMs between hosts; it is not a file transfer or software distribution mechanism.

D: Incorrect. vMotion is a live migration technology, not a backup or replication mechanism.

Question 10: Which of the following most accurately describes a storage area network (SAN) in the context of a VMware high availability cluster?

- A) A SAN provides local storage for each cluster host, isolated from other hosts to prevent single points of failure.
- B) A SAN presents shared storage volumes accessible from all cluster hosts, enabling VMs to be migrated or restarted on any host in the cluster.
- C) A SAN replaces the need for VMware HA by providing automatic failover at the storage layer.
- D) A SAN is required for VMware HA but not for DRS, since DRS uses memory-based migration.

Answer: B. Correct. Shared storage accessible to all cluster hosts is the prerequisite for both vMotion live migration (DRS) and VM restart on a different host (HA). Without shared storage, VM files are only accessible from the host where they reside.

A: Incorrect. A SAN provides shared storage — the same volumes are accessible from multiple hosts simultaneously. Local storage isolated per host is not shared storage and cannot support DRS or HA.

C: Incorrect. A SAN provides storage access, not compute workload restart. A SAN alone does not restart VMs when a host fails; that is HA's function.

D: Incorrect. vMotion, which DRS uses for live migration, requires that the VM's storage be accessible from both the source and destination hosts — which requires shared storage. Both DRS and HA need shared storage.